

PENTESTER TACTIC

PT-09

MULTI-VECTOR ATTACK - COORDINATED CAMPAIGN

TACTIC TYPE: Advanced Persistence / Multi-Stage

TARGET VECTORS: MALWARE, CREDENTIAL_ABUSE, NETWORK, DATA_EXFIL

DIFFICULTY: ADVANCED (defeat DC 14)

RESOLUTION (V2.0): Each phase is a separate roll against DC 14, with one chosen defense per roll (that phase's bonus list).

TEACHING POINT: Modern attacks are sophisticated and multi-faceted. No single defense can stop them. Comprehensive defense-in-depth with coordinated response is essential. Defense teams must practice responding to coordinated attacks.

DESCRIPTION

A pentester orchestrates a coordinated multi-vector attack that combines multiple tactics simultaneously: social engineering + malware + lateral movement + data exfiltration. Each phase is dependent on the previous one, and success in one area opens opportunities in others. Can your defenses coordinate to stop the full attack chain?

ATTACK DETAILS

Phase 1: Phishing delivers initial malware; Phase 2: Malware establishes persistence; Phase 3: Lateral movement to file server; Phase 4: Credential harvesting and exfiltration; Targets: Defense coordination, integrated threat response; Blue Team must roll separately for EACH phase;

DEFENDING DEFENSES

Phase 1 (Social Engineering): D-02 (+2), D-23 (+2) reduce success by +2 on this roll; Phase 2 (Malware): D-06 (+1), D-08 (+3), D-13 (+2), D-17 (+2) for this phase; Phase 3 (Lateral Movement): D-04 (+1), D-09 (+3), D-10 (+2), D-15 (+2) for this phase; Phase 4 (Data Exfil): D-11 (+4), D-22 (+2), D-24 (+1) for this phase; Card Effect – Full coverage: If Blue Team has deployed defenses covering all 4 targeted vectors, add +1 to each phase roll;

OUTCOME

Blue Team Succeeds (14+ on every phase roll): Comprehensive defense stops the attack chain; Blue Team Fails ANY phase: Attack progresses; Blue Team loses 1d4 security score points per failed phase and must deploy emergency response;

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-12

APT CAMPAIGN - MULTI-TURN PERSISTENT THREAT

TACTIC TYPE: Advanced Persistent Threat / Long-term Compromise

TARGET VECTORS: CREDENTIAL_ABUSE, MALWARE, NETWORK, DATA_EXFIL

DIFFICULTY: EXPERT+ (defeat DC 16)

SPECIAL RULE - ESCALATING DIFFICULTY: Each turn the APT remains undetected, DC increases by 1 (Turn 1: DC 16, Turn 2: DC 17, Turn 3: DC 18, etc.)

TEACHING POINT: APTs are sophisticated, well-resourced, and patient. They expect to remain undetected for months or years. Early detection is critical. Continuous monitoring, threat intelligence integration, and advanced hunting are essential for APT detection.

DESCRIPTION

A pentester simulates an Advanced Persistent Threat (APT) campaign that maintains presence across multiple turns. Each turn, the APT performs new reconnaissance, persistence, lateral movement, or data exfiltration activities. The Blue Team must detect and eradicate the APT before it achieves critical objectives. This is a multi-turn challenge that escalates difficulty.

ATTACK DETAILS

Multi-turn challenge (lasts 2-3 turns of main game); Targets: Long-term detection, threat hunting, incident response procedures; Each turn the APT performs an action; Blue Team must detect and respond; If APT achieves 3 objectives (e.g., 3 successful data exfil), game is lost;

TURN-BY-TURN APT ACTIONS

Turn 1: Reconnaissance (scan network, enumerate users, identify critical assets); Turn 2: Lateral movement (move to file server, domain controller); Turn 3: Persistence establishment (add backdoor, create hidden user account); Turn 4 (if still active): data exfiltration (steal customer database); Turn 5+ (if still active): Destruction phase (delete logs, trigger ransomware);

CONTINUED IN MODULE RULES

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-15

FIRMWARE/BIOS ATTACK - BOOTLOADER COMPROMISE

TACTIC TYPE: Persistence / Hardware-level Attack

TARGET VECTORS: MALWARE, NETWORK

DIFFICULTY: EXPERT (defeat DC 15)

SPECIAL FIRMWARE DEFENSE: If Blue Team deployed secure boot, TPM attestation, and hardware validation, add +2 additional bonus.

TEACHING POINT: Firmware attacks are extremely sophisticated but increasingly common in APT campaigns. Secure Boot and TPM are standard defenses but must be enabled and properly configured. Firmware supply chain security is critical. Organizations should consider firmware integrity verification in procurement.

DESCRIPTION

A pentester with physical or remote access targets system firmware (BIOS/UEFI) or bootloader, establishing persistence at the hardware level below the operating system. This attack survives OS reinstalls and even hardware replacement (if firmware is deployed via supply chain). Can your controls detect and prevent firmware-level attacks?

ATTACK DETAILS

Targets: Firmware integrity, secure boot verification, hardware attestation; Success indicates: Lack of UEFI Secure Boot, no firmware validation, no TPM; Blue Team rolls 1d20 to detect firmware tampering;

DEFENDING DEFENSES

D-16 (Credential Guard & Secure Boot): +3 bonus (UEFI Secure Boot prevents unauthorized firmware); D-17 (Malware Sandbox): +1 bonus only (doesn't catch firmware-level attacks); D-13 (Threat Hunting): +2 bonus (advanced hunting detects firmware persistence); New Special Defense - Hardware Attestation: +3 bonus (TPM verification detects firmware changes); New Special Defense - Supply Chain Verification: +2 bonus (validates firmware integrity from trusted source);

OUTCOME

Blue Team Succeeds (15+): Firmware tampering detected and system reimaged; Blue Team Fails: Firmware-level persistence established; -2 penalty to all rolls for remainder of game, Blue Team loses control of compromised system;

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-10

ZERO-DAY EXPLOITATION - UNKNOWN VULNERABILITY

TACTIC TYPE: Initial Access / Execution

TARGET VECTORS: MALWARE, WEB_EXPLOIT

DIFFICULTY: EXPERT (defeat DC 15)

SPECIAL RULE: If Blue Team has NOT deployed at least 2 of [D-08, D-13, D-17], they cannot succeed at this challenge (add clause: "You must have behavioral detection to stop unknown exploits").

TEACHING POINT: Signature-based defenses have inherent limitations. Behavioral detection and threat hunting are essential for detecting novel attacks. Zero-day preparedness requires assumption-of-breach mindset.

DESCRIPTION

A pentester exploits a previously unknown vulnerability (zero-day) in a critical business application. Traditional defenses (patching, signature-based detection, vulnerability scanning) cannot help because the vulnerability isn't public. Only behavioral detection or proactive hunting can identify this attack. Can your advanced monitoring catch what signature-based tools cannot?

ATTACK DETAILS

Targets: Signature-based defenses, unknown vulnerability management; Attack Vector: Unpatched but pristine application; Success indicates: Blind spots in behavioral detection; Blue Team rolls 1d20 to detect before exploitation succeeds;

DEFENDING DEFENSES

D-03 (Patching): +0 bonus (zero-day by definition isn't in patches); D-06 (Antivirus): +0 bonus (signatures don't exist for zero-day); D-08 (EDR): +3 bonus (behavioral analytics detect anomalous post-exploitation); D-13 (Threat Hunting): +3 bonus (proactive hunting finds zero-day activity); D-17 (Sandbox): +2 bonus (detonates malicious payloads in sandbox before deployment); D-18 (IPS): +1 bonus only (cannot stop unknown exploits); D-21 (Container Security): +2 bonus (isolates exploited application);

OUTCOME

Blue Team Succeeds (15+): EDR or threat hunting detects post-exploitation activity before damage; Blue Team Fails: Zero-day achieves initial access; Blue Team suffers -1 penalty to all rolls for remainder of game (blind spot in defenses);

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-13

CLOUD-SPECIFIC ATTACK - MISCONFIGURED CLOUD RESOURCES

TACTIC TYPE: Cloud Security / Privilege Escalation

TARGET VECTORS: MALWARE, CREDENTIAL_ABUSE, NETWORK, DATA_EXFIL

DIFFICULTY: ADVANCED (defeat DC 14)

SPECIAL CLOUD DEFENSE: If Blue Team deployed cloud-specific hardening (e.g., cloud security posture management tools, cloud-native IAM), add +2 bonus.

TEACHING POINT: Cloud security is fundamentally different from on-premises. Shared responsibility model requires organizations to actively manage cloud configuration. Cloud misconfigurations are the #1 cloud vulnerability. Continuous posture scanning is essential.

DESCRIPTION

A pentester discovers misconfigured cloud resources (S3 bucket, Azure storage, GCP database) that are accessible without authentication. They pivot from compromised workstation to cloud infrastructure, exfiltrating sensitive data stored in cloud. Can your cloud security controls catch this lateral movement into cloud?

ATTACK DETAILS

Targets: Cloud security posture management, identity & access management in cloud; Assumes: Blue Team has cloud infrastructure in their network design; Success indicates: Misconfigured cloud resources, weak cloud IAM policies; Blue Team rolls 1d20 to detect and remediate;

DEFENDING DEFENSES

D-04 (Firewall Rules): +1 bonus (limits cloud connectivity from compromised systems); D-20 (Zero Trust Access): +2 bonus (requires proper identity & authorization for cloud access); D-21 (Container Security): +2 bonus (blocks cloud API abuse if containerized); D-22 (SIEM Enterprise): +2 bonus (detects unusual cloud API calls); D-24 (Threat Intelligence): +1 bonus (known misconfigured bucket signatures); New Special Defense - Cloud Posture Mgmt: +3 bonus (automatically detects and remediates misconfigurations);

OUTCOME

Blue Team Succeeds (14+): Misconfiguration detected and remediated before exfiltration; Blue Team Fails: Cloud data is exfiltrated; -1 penalty to all rolls for remainder of game, plus immediate 15 Budget cost for cloud forensics;

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-16

PRIVILEGE ESCALATION - CONTAINERIZED ENVIRONMENT ESCAPE

TACTIC TYPE: Privilege Escalation / Container Escape

TARGET VECTORS: MALWARE, NETWORK

DIFFICULTY: EXPERT (defeat DC 15)

SPECIAL CONTAINER DEFENSE: If Blue Team has deployed comprehensive container security (runtime monitoring + pod security policies + network policies), add +2 additional bonus.

TEACHING POINT: Container security is distinct from traditional OS security. Container runtimes have historically had significant vulnerabilities. Runtime security monitoring is essential. Kubernetes network policies and pod security standards are critical controls. Organizations using containers must keep runtimes patched and actively monitor for escape attempts.

DESCRIPTION

A pentester, operating from within a compromised container, exploits a container runtime vulnerability (like CVE-2019-5736 runc exploit) to escape the container and gain access to the underlying host system. From there, lateral movement to other containers and host systems becomes possible. Can your container security and patching strategies prevent container escape?

ATTACK DETAILS

Targets: Container runtime patching, container isolation, runtime security; Assumes: Blue Team has containerized workloads (Docker, Kubernetes, etc.); Success indicates: Unpatched container runtime or lack of runtime monitoring; Blue Team rolls 1d20 to prevent or detect escape;

DEFENDING DEFENSES

D-03 (Patching): +2 bonus (ensures container runtime is patched); D-08 (EDR): +2 bonus (detects suspicious syscalls attempting escape); D-13 (Threat Hunting): +2 bonus (hunting for container escape indicators); D-21 (Container Security): +4 bonus (runtime security detects and blocks escape attempts); New Special Defense - Kubernetes Security Policies: +2 bonus (network policies and pod security policies restrict escape);

OUTCOME

Blue Team Succeeds (15+): Container escape prevented or detected before host compromise; Blue Team Fails: Attacker escapes container to host; immediate -1 for all subsequent attacks, gains ability to compromise other containers;

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-11

RANSOMWARE DEPLOYMENT & ENCRYPTION

TACTIC TYPE: Impact / Execution

TARGET VECTORS: MALWARE, DATA_EXFIL, NETWORK

DIFFICULTY: EXPERT (defeat DC 15)

SPECIAL RULE - IMMUTABLE BACKUP CHECK: If Blue Team deployed D-19, they also need verification that backups are immutable and tested. If backup testing procedures weren't mentioned in D-19 deployment, the bonus only applies if they roll 15+.

TEACHING POINT: Ransomware is now the #1 cybersecurity threat. Prevention through detection is important, but backup resilience is the ultimate defense. Immutable backups that survive ransomware attacks are essential business continuity strategy. Regular restore testing is critical.

DESCRIPTION

A pentester deploys ransomware that encrypts critical business data and demands payment for decryption keys. The attack combines malware execution, persistence, and data exfiltration (to threaten public disclosure if ransom not paid). This is the culmination of a successful attack chain. Can your defenses prevent data encryption, and can your backup strategy save you?

ATTACK DETAILS

Targets: Data availability, backup resilience, recovery procedures; Success indicates: Lack of backup redundancy or immutable backup protection; Blue Team rolls 1d20 to either: (A) prevent ransomware deployment, OR (B) recover from backup;

DEFENDING DEFENSES

Option A: Prevent Deployment; D-08 (EDR): +3 bonus (detects ransomware execution); D-13 (Threat Hunting): +2 bonus (proactive hunting finds ransomware); D-14 (Memory Forensics): +1 bonus (detects encryption process); D-17 (Sandbox): +2 bonus (detonates before reaching production); D-21 (Container Security): +2 bonus (prevents spread in containerized environments); Option B: Recover from Backup (if prevention fails); D-19 (Backup & Disaster Recovery): +4 bonus (3-2-1 backup strategy enables recovery); D-21 (Container Security): -1 bonus (containerized backups easier to restore); DC becomes 12 (easier to recover than prevent);

CONTINUED IN MODULE RULES

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

PENTESTER TACTIC

PT-14

IOT/OT COMPROMISE - INDUSTRIAL NETWORK ATTACK

TACTIC TYPE: Operational Technology Attack / Physical Safety Impact

TARGET VECTORS: NETWORK, MALWARE

DIFFICULTY: ADVANCED (defeat DC 14)

SPECIAL OT DEFENSE: If Blue Team has deployed OT-specific monitoring and segmentation, add +2 bonus.

TEACHING POINT: OT security is distinct from IT security. OT systems cannot be patched like IT systems. Network segmentation is the primary defense. OT-specific monitoring and threat hunting are essential. Organizations with manufacturing, utilities, or building management need specialized OT security strategies.

DESCRIPTION

A pentester compromises IoT or Operational Technology (OT) devices (industrial control systems, HVAC, building management, manufacturing systems) that are connected to the corporate network. Unlike IT systems (computers, servers), OT systems prioritize availability and cannot be patched frequently. Can your network architecture prevent OT compromise, and can you detect it before physical systems are affected?

ATTACK DETAILS

Targets: Network segmentation between IT and OT, OT-specific monitoring; Assumes: Blue Team has IoT/OT devices in their network design; Success indicates: Lack of network segmentation or OT-specific monitoring; Blue Team rolls 1d20 to detect and isolate;

DEFENDING DEFENSES

D-04 (Firewall Rules): +1 bonus (separates IT from OT traffic); D-09 (Network Segmentation): +3 bonus (dedicated OT segment with restricted access); D-10 (SIEM Correlation): +2 bonus (detects OT anomalies if properly tuned); D-22 (SIEM Enterprise): +2 bonus (advanced OT monitoring and correlation); New Special Defense - OT Monitoring: +3 bonus (specialized tools detect OT compromise);

OUTCOME

Blue Team Succeeds (14+): OT compromise detected and isolated before impact; Blue Team Fails: OT systems compromised; physical operations affected, -2 penalty to all rolls for remainder of game, plus potential safety/liability consequences (narrative impact);

INCIDENT ZERO - HARDENING

INCIDENT ZERO - HARDENING

